

RELATORIO TECNICO DE CORRECOES - VESTWEB

Documento de fechamento das melhorias implementadas a partir da auditoria backend.

Data de emissao: 25/04/2026

Escopo: codigo atual da branch de trabalho.

Resumo executivo:

- Itens mapeados da auditoria: 18
- Itens concluidos: 17
- Itens parcialmente concluidos: 1 (item 18 - cobertura de testes)
- Itens pendentes sem implementacao: 0

STATUS POR ITEM DA AUDITORIA

- 1) Credenciais reais expostas no repositorio - CONCLUIDO
Evidencias: .gitignore, server/.env.example, client/.env.example.
- 2) Stripe Secret Key no frontend - CONCLUIDO
Evidencias: client/.env.example usa apenas VITE_STRIPE_PUBLISHABLE_KEY.
- 3) Logout nao invalida token no servidor - CONCLUIDO
Evidencias: server/src/controllers/authController.js (logout destroi sessao).
- 4) JWT em localStorage (risco XSS) - CONCLUIDO
Evidencias: client/src/api/api.ts com withCredentials e limpeza de token legado; auth usa cookie HTTP-only no backend.
- 5) Sem rate limiting (login/pagamento) - CONCLUIDO
Evidencias: server/src/middlewares/rateLimitMiddleware.js; server/src/routes/authRoutes.js; server/src/routes/paymentRoutes.js.
- 6) Sem headers de seguranca HTTP - CONCLUIDO
Evidencias: helmet aplicado em server/app.js.
- 7) CORS hardcoded para localhost - CONCLUIDO
Evidencias: CORS_ALLOWED_ORIGINS/CLIENT_URL via env em server/app.js.
- 8) error.message exposto ao cliente - CONCLUIDO
Evidencias: handler global retorna mensagem generica para erros 5xx.
- 9) Sem validacao de schema na API - CONCLUIDO
Evidencias: schemaValidationMiddleware + validators (auth/payment/questions).

STATUS POR ITEM DA AUDITORIA (CONT.)

- 10) Sem logging estruturado - CONCLUIDO
Evidencias: server/src/services/logger.js (pino) e requestLoggerMiddleware.
- 11) Banco usando usuario admin (postgres) - CONCLUIDO
Evidencias: DB_RUNTIME_* em server/src/db/index.js + script server/scripts/provision-runtime-db-user.js.
- 12) Sem sanitizacao na comunidade - CONCLUIDO
Evidencias: DOMPurify no server/src/controllers/communityController.js.
- 13) Ausencia de health check endpoint - CONCLUIDO
Evidencias: GET /health em server/app.js (status + database).
- 14) JWT secret fraco - CONCLUIDO
Evidencias: validacao de tamanho/entropia em jwtService.js.

15) Pool PostgreSQL sub-dimensionado - CONCLUIDO

Evidencias: DB_POOL_MAX/MIN/ACQUIRE/IDLE em server/src/db/index.js.

16) Sem Docker para deploy consistente - CONCLUIDO

Evidencias: server/Dockerfile e server/.dockerignore.

17) Sem versionamento de API - CONCLUIDO

Evidencias: server/app.js com /api/v1 e client/src/api/api.ts com /api/v1.

18) Cobertura de testes incompleta - PARCIALMENTE CONCLUIDO

Evidencias: novos testes unitarios para webhook/limites/rotas.

Observacao: testes de integracao e frontend ainda apresentam falhas pre-existentes.

RESULTADOS DE VALIDACAO

Comandos executados:

- Backend unitario: npm run test -- tests/unit --runInBand

Resultado: APROVADO (17 suites, 125 testes).

- Backend integracao: npm run test -- tests/integration --runInBand

Resultado: FALHOU (auth.test.js: export Teacher ausente em ../db/models/index.js).

- Frontend testes: npm run test

Resultado: FALHOU (LoginPage.test.tsx com seletor ambiguo /senha/i).

- Frontend build: npm run build

Resultado: FALHOU (erros TypeScript pre-existentes em testes/paginas).

Conclusao tecnica:

As correcoes de seguranca, resiliencia e padronizacao da API foram aplicadas no backend.

A estabilizacao total da esteira (integration/frontend) depende de um ciclo adicional de correcoes de testes e tipagem no client.

Fim do relatorio.